INTERAFAS-LAB

Pulso Metropolitano

Plan de Respuesta ante Incidentes de Seguridad

Ciclo PICERL (NIST SP 800-61 Rev. 2) y CISA Incident/Vulnerability Response Playbooks

PR02 · Blindando la información: gobernanza y cumplimiento

Juan Francisco Ortega Jiménez

Matrícula: 184918

7.° semestre · Ingeniería en Tecnologías de la Información

Sistemas de Gestión de la Seguridad

Mtro. Servando López Contreras

Universidad Politécnica de San Luis Potosí (UPSLP)

San Luis Potosí, 12 de octubre de 2026 · Versión 2.0

Tabla de contenido

1. Propósito, alcance y marco de referencia 3
2. Equipo de respuesta a incidentes (CSIRT) 3
3. Clasificación y niveles de severidad 3
4. Preparación 4
5. Identificación 4
6. Playbooks de respuesta por escenario 4
7. Erradicación (acciones generales por clase de hallazgo) 7
8. Recuperación (criterios generales) 7
9. Lecciones aprendidas 8
10. Herramientas y fuentes de evidencia 8
11. Relación con los demás entregables 8

1. Propósito, alcance y marco de referencia

Este plan define el proceso que el equipo de seguridad de Pulso Metropolitano debe seguir para detectar, contener, erradicar y recuperarse de incidentes de seguridad de la información sobre el alcance del SGSI (portal corporativo, APIs internas y red operacional OT). Se adopta el ciclo PICERL (Preparación, Identificación, Contención, Erradicación, Recuperación, Lecciones aprendidas) de la guía NIST SP 800-61 Rev. 2 (Computer Security Incident Handling Guide).

Como referencia metodológica complementaria para la estructura de los playbooks por escenario (sección 6), se adoptan los "Federal Government Cybersecurity Incident and Vulnerability Response Playbooks" de la Cybersecurity and Infrastructure Security Agency (CISA), que definen de forma prescriptiva las fases de preparación, detección/análisis, contención/erradicación/recuperación y actividades posteriores al incidente, así como un playbook específico para el manejo de vulnerabilidades.

Este plan es la contraparte técnica del Plan de Comunicación de Crisis: comparte la misma escala de severidad (sección 3) para que ambos se activen de forma sincronizada, y alimenta con sus hallazgos técnicos verificados el proceso de comunicación externa/interna.

2. Equipo de respuesta a incidentes (CSIRT)

Rol	Responsabilidad
Líder de respuesta a incidentes (Incident Commander)	Coordina todo el ciclo PICERL; decide escalamiento y declara el cierre del incidente
Analista de seguridad IT	Investiga la capa de aplicación web/API (inyección, control de acceso, sesión)
Oficial de Seguridad OT	Investiga y contiene incidentes sobre la red operacional (HMI, firmware, telemetría)
Administrador de sistemas / infraestructura	Ejecuta acciones de contención técnica (aislar segmentos, revocar credenciales, revertir configuración)
Enlace legal / cumplimiento	Evalúa obligaciones regulatorias y de preservación de evidencia
Gerencia de Atención a Usuarios	Identifica usuarios afectados y coordina con el equipo de comunicación de crisis
Enlace con el equipo de comunicación de crisis	Traduce hallazgos técnicos verificados al Plan de Comunicación de Crisis, sin filtrar detalles de explotación

3. Clasificación y niveles de severidad

Escala compartida con el Plan de Comunicación de Crisis para garantizar una respuesta sincronizada. La severidad se determina por el impacto real o potencial sobre confidencialidad, integridad y, de forma prioritaria en el contexto OT, disponibilidad del servicio.

Nivel	Etiqueta	Criterio	Respuesta del CSIRT
1	Bajo	Exposición de información sin explotación activa confirmada	Registro y remediación en el ciclo normal; sin activación de CSIRT completo
2	Medio	Acceso no autorizado a datos de alcance limitado, sin persistencia	Analista IT asignado; contención en ≤ 24 horas
3	Alto	Compromiso con impacto financiero o de múltiples cuentas	CSIRT completo; contención en ≤ 4 horas
4	Crítico	Cruce confirmado de la frontera IT→OT	CSIRT completo + Oficial OT; contención en ≤ 1 hora; activación preventiva del Plan de Comunicación de Crisis
5	Catastrófico	Impacto confirmado en disponibilidad del proceso físico	CSIRT completo + activación inmediata del Plan de Comunicación de Crisis; posible invocación de continuidad de negocio

4. Preparación

- Mantener actualizado el inventario de los 20 activos de información IT/OT definidos en el SGSI (sección 04).
- Garantizar que el Portal del Auditor y su bitácora de actividad permanezcan activos como fuente primaria de evidencia.
- Mantener vigente la lista de contacto del CSIRT (sección 2) y los accesos de emergencia necesarios para contención.
- Ejecutar ejercicios periódicos de auditoría ofensiva, como el documentado en el Informe de Vulnerabilidades, para validar que los controles de detección y contención funcionan antes de un incidente real.

5. Identificación

- Fuentes de detección en el alcance: bitácora del Portal del Auditor, indicadores del HMI operacional (escalada de averías, caída de disponibilidad), encabezados de respuesta anómalos.
- Al confirmar el incidente, documentar de inmediato: hora de detección, sistemas afectados, indicadores observados, y severidad preliminar conforme a la sección 3.
- Seleccionar el playbook aplicable (sección 6) según el escenario identificado.

6. Playbooks de respuesta por escenario

Se definen cinco playbooks, cada uno estructurado según el disparador que lo activa, los responsables de ejecutarlo, las acciones de investigación, la evidencia a preservar, las medidas de contención y recuperación, y el criterio objetivo para declarar su cierre — formato alineado a los CISA Incident Response Playbooks.

PB-01 · Compromiso de aplicación web por control de acceso roto (IDOR / BOLA) o inyección SQL

Hallazgos de referencia: Retos 3, 6, 7, 12

Disparador	Alerta de acceso a un recurso (expediente, cuenta o endpoint) cuyo identificador no corresponde al usuario autenticado, o respuesta de base de datos anómala (errores SQL, tiempos de respuesta inconsistentes) detectada en la bitácora del Portal del Auditor o en el WAF.
Responsables	Analista de seguridad IT (ejecuta) · Líder de respuesta / Incident Commander (decide escalamiento) · Administrador de sistemas (aplica bloqueos)
Acciones	1) Confirmar el patrón de acceso anómalo correlacionando IP, cuenta y objeto solicitado. 2) Determinar el alcance: cuántos objetos/cuentas distintas fueron consultadas fuera del propietario legítimo. 3) Verificar si existe evidencia de exfiltración (volumen de respuesta, número de solicitudes) o de modificación de datos.
Evidencia	Bitácora de solicitudes HTTP (método, ruta, parámetros, código de respuesta), consultas SQL registradas por el motor de base de datos, identificador de sesión y cuenta de origen; conservar en el expediente del incidente antes de cualquier purga de logs.
Contención	Revocar/invalidar la sesión y las credenciales del origen del abuso; aislar temporalmente el endpoint afectado (deshabilitar la ruta o aplicar una regla de WAF) si la explotación está activa; bloquear la IP de origen si es

	externa y no corresponde a tráfico legítimo.
Recuperación	Reactivar el endpoint únicamente después de desplegar la validación de autorización por objeto o las consultas parametrizadas (ver sección de erradicación); monitorear 72 horas en busca de reintentos.
Criterio de cierre	El vector queda reproduciblemente bloqueado en un entorno de prueba, no hay cuentas ni objetos pendientes de verificar, y el informe post-incidente (sección 9) fue documentado.

PB-02 · Exposición de información por archivos públicos, respaldos o rutas fuera del directorio autorizado

Hallazgos de referencia: Retos 1, 2, 4, 5, 9, 15

Disparador	Hallazgo (interno o reportado por un tercero) de un archivo de configuración, respaldo (.bak) o documento interno accesible desde una ruta pública, o acceso confirmado fuera del directorio autorizado mediante manipulación de rutas (path traversal).
Responsables	Analista de seguridad IT (ejecuta) · Administrador de sistemas (retira el archivo y ajusta permisos) · Enlace legal/cumplimiento (si el archivo contiene datos personales)
Acciones	1) Confirmar el contenido exacto del archivo/ruta expuesta y si contiene secretos, credenciales o datos personales. 2) Revisar los logs de acceso para determinar si el recurso fue descargado por terceros no autorizados y desde qué origen. 3) Identificar si existen artefactos similares expuestos (barrido de extensiones y rutas equivalentes).
Evidencia	Copia forense del archivo expuesto, logs de acceso al recurso (IP, fecha/hora, user-agent), resultado del barrido de rutas equivalentes.
Contención	Retirar de inmediato el archivo o restringir el acceso a la ruta; si el acceso fue por manipulación de rutas, bloquear temporalmente el parámetro/función vulnerable.
Recuperación	Reponer el servicio una vez aplicado el mapeo indirecto de rutas o el filtro de publicación (checklist de la política AI-01/AI-03/AI-06 del SGSI); confirmar que no quedan artefactos equivalentes expuestos.
Criterio de cierre	El barrido de verificación no encuentra artefactos expuestos equivalentes y, si hubo datos personales involucrados, el enlace legal documenta la evaluación correspondiente.

PB-03 · Entrada maliciosa persistente en canal ciudadano (XSS almacenado)

Hallazgos de referencia: Reto 8

Disparador	Reporte de comportamiento anómalo en el navegador de un usuario al visualizar contenido generado por otro usuario (p. ej. un reporte ciudadano), o detección de una carga de script en el contenido almacenado durante una revisión rutinaria.
Responsables	Analista de seguridad IT (ejecuta) · Gerencia de Atención a Usuarios (identifica a los usuarios potencialmente afectados) · Administrador de sistemas (purga el contenido)
Acciones	1) Localizar y aislar el registro que contiene la carga maliciosa. 2) Determinar cuántos usuarios visualizaron el contenido comprometido desde su publicación. 3) Analizar la carga para descartar que haya sido diseñada para exfiltrar sesiones u otros datos.
Evidencia	Copia del registro con la carga original, lista de visualizaciones del contenido (si el sistema las registra), versión del campo antes y después

	de la purga.
Contención	Despublicar o neutralizar de inmediato el contenido afectado; invalidar las sesiones de los usuarios que lo visualizaron si existe indicio de robo de sesión.
Recuperación	Reactivar el canal de publicación una vez desplegada la sanitización de entrada y codificación de salida contextual; realizar una prueba de regresión con una carga de control.
Criterio de cierre	La prueba de regresión confirma que la carga de control es neutralizada, y no hay reportes de sesiones comprometidas asociadas al incidente.

PB-04 · Cruce no autorizado de la frontera IT→OT (bypass de autenticación, sesión de mantenimiento con privilegio excesivo o firmware no verificado)

Hallazgos de referencia: Retos 16, 18, 19

Disparador	Tráfico desde la red IT aceptado en el gateway operacional sin autenticación verificable, una sesión de mantenimiento ejerciendo privilegios fuera de su alcance declarado, o una actualización de firmware aplicada sin verificación de firma — detectado por el registro del gateway, del HMI o del propio proceso de actualización.
Responsables	Oficial de Seguridad OT (ejecuta y decide) · Líder de respuesta / Incident Commander (escala y activa comunicación de crisis) · Administrador de sistemas (aísla el segmento IT)
Acciones	1) Confirmar el alcance real ejercido contra el alcance autorizado de la sesión o del tráfico. 2) Verificar si hubo modificación de configuración, parámetros o firmware durante la ventana del incidente. 3) Determinar si el acceso se originó por una cabecera/token falsificado o por credenciales comprometidas.
Evidencia	Registro del gateway IT-OT, registro de la sesión de mantenimiento (alcance declarado vs. ejercido), hash/firma del firmware aplicado, estado de los parámetros operacionales antes y después del evento.
Contención	Revocar de inmediato toda sesión de mantenimiento activa y rotar sus credenciales; bloquear en el gateway cualquier tráfico que falsifique el origen de red; congelar la capacidad de actualización remota de firmware hasta cerrar el vector.
Recuperación	Restaurar el acceso de mantenimiento únicamente bajo el modelo de mínimo privilegio y acceso temporal (just-in-time); reponer la verificación de firma de firmware antes de permitir nuevas actualizaciones.
Criterio de cierre	El Oficial de Seguridad OT confirma que no existen sesiones con alcance excedido activas, el gateway exige autenticación verificable en el 100% de las rutas probadas, y se activó —si la severidad lo ameritaba— el Plan de Comunicación de Crisis.

PB-05 · Acceso no autorizado a funciones críticas del HMI o manipulación de parámetro operacional fuera de rango seguro

Hallazgos de referencia: Retos 17, 20

Disparador	Ejecución de una función crítica del HMI sin autenticación, o cambio de un parámetro de control (dosificación, presión, niveles) fuera del rango operacional seguro, detectado por el propio sistema de control, por el enclavamiento físico/lógico o por el indicador de disponibilidad del proceso.
Responsables	Oficial de Seguridad OT (ejecuta y decide) · Dirección de Operaciones

	(autoriza acciones físicas) · Líder de respuesta / Incident Commander (activa comunicación de crisis de forma inmediata)
Acciones	1) Verificar de inmediato el estado físico real del proceso (no solo el valor reportado por el software) a través de instrumentación independiente si existe. 2) Determinar el origen de la instrucción (usuario, sesión, IP) que generó el cambio. 3) Evaluar si el enclavamiento de seguridad actuó correctamente.
Evidencia	Registro del HMI (usuario, hora, valor anterior y nuevo del parámetro), estado del enclavamiento físico/lógico, indicador de disponibilidad/averías del proceso antes y después del evento.
Contención	Activar de inmediato el enclavamiento físico o de controlador si no se activó automáticamente; revertir el parámetro afectado al último valor validado de ingeniería; exigir autenticación y registro de auditoría en toda función crítica del HMI mientras dure la contención.
Recuperación	Restablecer operación normal solo tras confirmar que el parámetro está dentro de rango seguro y que el vector de acceso que permitió la manipulación fue cerrado; monitoreo reforzado de disponibilidad durante 72 horas.
Criterio de cierre	El parámetro crítico se mantiene dentro de rango seguro durante el periodo de monitoreo reforzado, el enclavamiento fue validado, y el Plan de Comunicación de Crisis fue activado y documentado conforme a su línea de tiempo.

7. Erradicación (acciones generales por clase de hallazgo)

Clase de vulnerabilidad	Acción de erradicación
Exposición de información / configuración	Eliminar artefactos expuestos, limpiar mensajes de error en producción, restringir endpoints de diagnóstico
Control de acceso roto (IDOR/BOLA)	Implementar validación de pertenencia del objeto y de rol en cada endpoint del lado del servidor
Inyección y XSS	Migrar a consultas parametrizadas; aplicar codificación de salida contextual y CSP
Gestión de sesión / autenticación	Regenerar identificadores de sesión, eliminar confianza en cabeceras de cliente, exigir firma criptográfica de firmware
Lógica de negocio	Revalidar en servidor montos de pago y relaciones contractuales antes de confirmar cualquier transacción
Exceso de privilegio OT	Redefinir el alcance de las sesiones de mantenimiento con autorización de grano fino (just-in-time)
Validación de parámetros críticos	Implementar validación de rango físico/operacional en servidor y enclavamientos independientes

8. Recuperación (criterios generales)

- Validar en un entorno controlado que la remediación aplicada bloquea el vector original, idealmente reejecutando el mismo paso de explotación documentado en el Informe de Vulnerabilidades.
- Restaurar servicios progresivamente, monitoreando activamente indicadores de reaparición del comportamiento anómalo.
- Confirmar con el Oficial de Seguridad OT que los parámetros físicos/operacionales están dentro de rango seguro antes de declarar el incidente contenido.

- Informar al equipo de comunicación de crisis el estado de recuperación para su actualización a clientes y reguladores.

9. Lecciones aprendidas

Dentro de los 10 días hábiles posteriores al cierre, el CSIRT documenta un informe post-incidente que retroalimenta el SGSI (sección 10, Mejora), conforme a la actividad "Post-Incident Activity" de NIST SP 800-61 y a la fase de cierre de los playbooks de CISA.

Campo	Contenido
ID del incidente	Identificador único, correlacionado con el playbook aplicado (sección 6)
Severidad asignada	Nivel 1-5 (sección 3) y justificación
Cronología	Hora de detección, contención, erradicación y recuperación
Causa raíz	Clasificación OWASP/CWE del hallazgo, como en el Informe de Vulnerabilidades
Impacto	Sistemas, datos y/o disponibilidad afectados (tríada CIA)
Acciones de contención y erradicación	Resumen del playbook ejecutado y de la erradicación aplicada
Brechas del proceso	Qué falló en la detección/respuesta y por qué
Acciones de mejora	Controles nuevos o reforzados, con responsable y fecha compromiso; se incorporan a la matriz de riesgo y al checklist de mejora del SGSI

10. Herramientas y fuentes de evidencia

- Portal del Auditor: banderas, puntuación técnica y bitácora detallada de actividad (equivalente funcional a un panel SIEM/SOC en este laboratorio).
- Encabezados de respuesta HTTP personalizados del entorno: fuente primaria de confirmación técnica de cada hallazgo.
- DevTools del navegador (pestaña Network): captura de peticiones/respuestas reales para diferenciar tráfico legítimo de ruido.
- Exportación CSV del log de actividad: evidencia exportable y con sello de tiempo para el expediente del incidente.

11. Relación con los demás entregables

Este plan opera en conjunto con el Informe de Vulnerabilidades (evidencia técnica base de cada hallazgo), el SGSI ISO/IEC 27001:2022 (marco de gobernanza, activos, políticas y matriz de riesgo) y el Plan de Comunicación de Crisis (contraparte de comunicación externa/interna), formando el conjunto completo de entregables del proyecto PR02 sobre INTERAFAS-LAB.